

Cyber Threat Intelligence

Executive Briefing

Report Date: July 04, 2026

Generated: 2026-07-04 23:15 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	11	4	1	20

2. Executive Summary

As of July 04, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, consisting of 4 Critical, 11 High, 4 Medium, and 1 Low severity findings. This volume of critical-tier exposure represents a High risk posture, indicating that systemic weaknesses in authentication and input sanitization could facilitate unauthorized system access if left unaddressed. The primary threat is CVE-2026-49360, Unauthenticated SQL Execution in Recce Server, which is prioritized due to its potential for direct database manipulation via unvalidated input. Consequently, the organization must adopt an aggressive remediation posture, mandating the immediate deployment of patches and compensatory controls for all Critical and High-rated findings to maintain operational integrity.

3. Critical Action List

- CVE-2026-49360: Immediate isolation of the Recce server and application of vendor-supplied patches within 12 hours.
- CVE-2026-49352: Rotate all JWT secrets and update the 9router configuration to utilize secure, dynamic key management within 24 hours.
- CVE-2026-54617: Implement strict input path sanitization filters on LaunchServer to block directory traversal attempts by 12:00 PM EST, July 5, 2026.
- CVE-2026-52830: Deploy updated bearer token validation logic for fast-mcp-telegram within 24 hours to prevent unauthorized access.
- CVE-2026-50194: Configure Steeltoe management ports to reject requests with unrecognized Host headers within 48 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-49360	Unauthenticated SQL Execution in ...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	Hardcoded JWT Secret in 9router	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Path Traversal in LaunchServer Fi...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Bearer Token Bypass in fast-mcp-t...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Management Port Bypass in Steeltoe	8.2	High	74/100	CWE-288
CVE-2026-2092	Unauthorized SAML Access in Keycl...	7.7	High	69/100	CWE-1287
CVE-2026-49353	Access Gate Bypass in 9router	7.5	High	68/100	CWE-290
CVE-2026-46599	Resource Exhaustion in golang.org...	7.5	High	68/100	CWE-770
CVE-2026-52792	Source Disclosure via NTFS Filena...	7.5	High	68/100	CWE-69
CVE-2026-50200	Connection String Leakage in Stee...	7.5	High	68/100	CWE-200
CVE-2026-50196	Registry Poisoning in Steeltoe Eu...	7.5	High	68/100	CWE-20
CVE-2026-49289	Denial of Service in SimpleSAMLphp	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Misbehavior in Zebra Addr...	7.5	High	68/100	CWE-617
CVE-2026-52834	Memory Corruption in jxl-grid on ...	8.6	High	66/100	CWE-122
CVE-2026-49284	Improper SAML Assertion Handling ...	8.2	High	64/100	CWE-345
CVE-2026-50201	Sensitive Actuators Exposed in St...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	JWKS Cache Sharing Vulnerability ...	5.9	Medium	53/100	CWE-668
CVE-2026-50267	Insecure TLS Private Key Storage ...	4.7	Medium	42/100	CWE-312
CVE-2026-49292	Unauthorized DB Access in Kiwi TC...	6.5	Medium	34/100	CWE-862
CVE-2026-50268	Insecure Padding Configuration in...	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: Unauthenticated SQL Execution in Recce Server

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server's database interface fails to validate input before processing queries via the integrated DuckDB engine. This flaw stems from a lack of authentication and input sanitization on the management endpoint, allowing direct access to database operations. An unauthenticated remote attacker can leverage this to read or overwrite local files,

leading to full system compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specifically crafted SQL query to the Recce server management endpoint. The server processes this query through the DuckDB interface without verifying the origin or the intent of the request. The DuckDB engine executes the operation, allowing the attacker to interact with the underlying filesystem through SQL commands. This results in the unauthorized retrieval or modification of sensitive local data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-49352

Finding: Hardcoded JWT Secret in 9router

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1552, T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

9router uses a static, hardcoded fallback secret to sign JWT tokens, facilitating bypass of authentication mechanisms. This implementation error allows any user to generate valid, signed tokens by using the publicly known or easily guessable fallback secret. Consequently, an unauthenticated attacker can impersonate administrative users and gain full control over the application environment.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the hardcoded JWT secret used by the 9router authentication module. The attacker crafts a valid JWT payload asserting administrative privileges and signs it using the identified static secret. This token is then provided in the header of subsequent requests to protected API endpoints. The system validates the signature, grants the attacker the associated privileges, and grants access to administrative functionality.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Path Traversal in LaunchServer FileServerHandler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1083, T1555

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The FileServerHandler in LaunchServer contains a path traversal vulnerability due to improper sanitization of directory traversal characters in file requests. An unauthenticated attacker can manipulate the file path parameter to escape the intended document root directory. This results in unauthorized access to sensitive local files, violating confidentiality and integrity constraints.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP GET request to the LaunchServer FileServerHandler with a path parameter containing encoded '..%2f' sequences. The application does not normalize or validate the requested path, resolving it to a sensitive file location outside the restricted directory. The server proceeds to read the file and returns its content in the HTTP response. This allows the attacker to exfiltrate critical configuration files or source code from the host machine.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Bearer Token Bypass in fast-mcp-telegram

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official
MITRE ATT&CK: T1083, T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram component suffers from a path traversal vulnerability involving Bearer token validation, which bypasses Telegram session protection. The issue stems from insufficient input validation when parsing token paths, allowing attackers to access unauthorized session contexts. Successful exploitation grants an unauthenticated attacker full control over the Telegram interface session.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the Telegram session endpoint with a path parameter containing traversal characters. The fast-mcp-telegram component fails to sanitize the path, allowing the attacker to reference an unauthorized, existing Telegram session token. The application loads this session into the current request context, bypassing the expected authentication check. The attacker then gains complete control over the victim's Telegram session, enabling the reading and sending of messages.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Management Port Bypass in Steeltoe

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official
MITRE ATT&CK: T1133, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	Low	Availability Impact	None

Description:

Steeltoe is vulnerable to management-port isolation bypass via spoofed Host headers during application request routing. The framework relies on the Host header to enforce separation between standard user traffic and administrative traffic, which can be easily circumvented. An attacker can leverage this to send unauthorized requests to management endpoints intended for internal use.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a management endpoint that is usually restricted to specific ports or headers. The attacker crafts an HTTP request and sets the Host header to match the internal management interface domain. The Steeltoe routing logic trusts the forged Host header and directs the request to the restricted administrative handler. This results in the attacker gaining unauthorized access to internal management tools and service configuration.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: Unauthorized SAML Access in Keycloak

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official
MITRE ATT&CK: T1133, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network	Attack Complexity	High
Privileges Required	Low	User Interaction	None
Scope	Changed	Confidentiality Impact	High
Integrity Impact	Low	Availability Impact	Low

Description:

Keycloak fails to properly validate encrypted SAML assertions, leading to unauthorized access. The root cause is a

deficiency in the verification logic applied to encrypted SAML tokens, allowing them to be bypassed under specific cryptographic configurations. This vulnerability enables authenticated users to gain unauthorized access to protected resources via forged or manipulated SAML assertions.

Proof of Concept (PoC):

An authenticated user with low privileges identifies the SAML endpoint and crafts an encrypted SAML assertion with escalated identity claims. The user submits this assertion to the authentication portal, bypassing the integrity check because Keycloak does not adequately validate the encrypted envelope. The authentication service accepts the forged assertion and grants the user the requested escalated privileges. This results in unauthorized access to sensitive application components reserved for higher-privileged accounts.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Access Gate Bypass in 9router

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190, T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The 9router application exhibits a flawed implementation of local-only access controls, permitting bypass via HTTP Host header manipulation. This vulnerability arises because the router relies on user-supplied headers to verify if the request originated from a trusted internal source. An unauthenticated attacker can forge the Host header to gain unauthorized access to restricted local administrative gates.

Proof of Concept (PoC):

An unauthenticated remote attacker captures a request directed at the 9router internal interface. The attacker modifies the Host header in the request packet to represent an internal, trusted hostname. The 9router validation logic erroneously accepts the forged header as verification of internal origin. This allows the attacker to bypass the intended access restrictions and interact with restricted administrative functionality.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Resource Exhaustion in golang.org/x/image/tiff

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The PackBits decompression function in `golang.org/x/image/tiff` fails to properly restrict memory allocation when processing maliciously crafted TIFF headers. The root cause is an absence of bounds checking on compression ratios, leading to excessive resource consumption during decompression operations. A remote attacker can trigger this condition by supplying a specially crafted TIFF image, resulting in a denial-of-service state.

Proof of Concept (PoC):

An unauthenticated remote attacker uploads a malformed TIFF image to an application utilizing the `golang.org/x/image/tiff` library. The PackBits decompression method begins processing the image and attempts to allocate memory based on the exaggerated length specified in the file. The library fails to validate the allocation size, exhausting available server memory rapidly. This causes the target process or system to crash, resulting in effective denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-52792**Finding: Source Disclosure via NTFS Filename in Algernon**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1046, T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Algernon, when running on Windows, is susceptible to server-side script source disclosure by exploiting NTFS filename behavior during request handling. The vulnerability arises because the server does not account for specific Windows-style filename normalization that bypasses script execution handlers. A remote attacker can trigger this to force the server to return raw script code instead of executing it, exposing sensitive business logic.

Proof of Concept (PoC):

An unauthenticated remote attacker appends a trailing character or alternate stream suffix that triggers specific NTFS file resolution behaviors in the Algernon web server. The request is passed to the server, which skips the server-side scripting interpreter due to the malformed path. The server treats the script file as a static resource and serves its raw source code in the HTTP response. The attacker successfully downloads the source code, potentially revealing

hardcoded credentials and proprietary algorithms.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50200

Finding: Connection String Leakage in Steeltoe

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official
MITRE ATT&CK: T1552, T1082

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe environment sanitizer fails to filter connection strings, resulting in the leakage of embedded database passwords in operational outputs. This oversight is due to an incomplete configuration of the sanitization regex patterns applied to sensitive environment variables. An attacker can access these outputs to obtain database credentials, enabling unauthorized data access.

Proof of Concept (PoC):

An unauthenticated remote attacker requests a Steeltoe actuator endpoint that displays environment variables. The framework's sanitizer processes the output but overlooks connection string patterns containing database passwords. The sensitive credentials are returned in cleartext to the attacker's browser. With these credentials, the attacker can connect directly to the backend database, resulting in unauthorized data exfiltration.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Registry Poisoning in Steeltoe Eureka Discovery

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official
MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Steeltoe's Eureka discovery client improperly handles unrecognized DataCenterInfo.Name values, allowing them to poison the entire service registry fetch process. This vulnerability arises from poor input validation when processing registry response objects from the Discovery server. An attacker can cause a denial of service across the registry by providing malformed service registration data.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a malicious registration request to the Eureka discovery server. The request includes an unconventional DataCenterInfo.Name that causes the client-side parsing logic in Steeltoe to enter an error loop or crash. Subsequent service discovery attempts by other clients fail as the registry fetch is poisoned by the malformed data. This leads to a widespread service outage within the microservices cluster.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: Denial of Service in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service attack via resource-intensive XPath transform operations performed on unsanitized XML input. The root cause is the lack of recursion limits or payload size constraints within the XPath processing module. An attacker can submit an excessively deep or complex XML structure that exhausts CPU resources, causing the application to hang.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specifically crafted SAML response containing a highly nested or malicious XPath query to the SimpleSAMLphp application. The library begins processing the XML and performs expensive XPath transformations without verifying the complexity or resource usage. The server CPU usage spikes to 100%, causing the application to stop responding to all legitimate user requests. This results in an effective and sustained denial of service for the SAML-based authentication system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Misbehavior in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book encounters an abort-level crash when handling specific IPv4-mapped address representations due to inconsistent mempool management. This occurs because the application fails to handle memory allocation for non-standard IPv4/IPv6 mapped formats appropriately. An unauthenticated attacker can supply a malicious network connection request to cause this condition, resulting in service interruption.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates a connection to the Zebra Address Book using a specifically formatted IPv4-mapped address that triggers the internal error handling logic. The address book service encounters an unexpected state in its memory management pool while trying to parse the address. This inconsistency triggers an assertion failure or a critical error that aborts the process immediately. The entire address book service crashes, resulting in denial of service until the service is manually restarted.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>**CVE-2026-52834****Finding: Memory Corruption in jxl-grid on 32-bit Systems****CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122**

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1203, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid library on 32-bit platforms contains an out-of-bounds write vulnerability triggered by an integer overflow during grid indexing calculations. This occurs because the library fails to perform necessary range checks when computing memory offsets for array operations. An attacker can supply malformed data to trigger this overflow, resulting in memory corruption and potential code execution.

Proof of Concept (PoC):

An attacker transmits a specially crafted request that causes the jxl-grid component to process grid dimensions

exceeding the limits of 32-bit memory indexing. The internal index calculation wraps around due to integer overflow, resulting in a target pointer that lies outside the allocated memory region. The application writes data to this unintended memory location, overwriting critical heap structures. This can eventually be exploited to gain remote code execution on the server processing the grid data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: Improper SAML Assertion Handling in SimpleSAMLphp

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1558, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The SimpleSAMLphp Service Provider incorrectly validates SAML responses when an unsigned Response is paired with a signed Assertion that lacks proper InResponseTo metadata. This logic gap allows an attacker to inject a response from an unexpected Identity Provider. This violation of the trust model can lead to unauthorized access and session hijacking for unsuspecting users.

Proof of Concept (PoC):

An unauthenticated attacker directs a user to their malicious SAML Identity Provider and initiates a SAML response workflow. The attacker sends a signed assertion lacking the expected InResponseTo identifier to the SimpleSAMLphp Service Provider. Because the SP fails to verify the linkage between the response and the request, it treats the assertion as legitimate. This allows the attacker to successfully impersonate a valid user session within the target application.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

CVE-2026-50201

Finding: Sensitive Actuators Exposed in Steeltoe

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: CNA Official

MITRE ATT&CK: T1082, T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe actuators such as heapdump and env endpoints are configured with overly permissive access, requiring only the 'Restricted' role. This vulnerability is the result of improper default authorization settings applied to sensitive operational endpoints. An attacker with minimal access can leverage these endpoints to leak internal environment data and memory snapshots.

Proof of Concept (PoC):

An authenticated user with low-level 'Restricted' access targets the Steeltoe actuator endpoints at /actuator/heapdump and /actuator/env. The application grants the user access because the endpoint protection does not distinguish between administrative and restricted roles. The attacker requests the endpoints and receives a complete memory heap dump and environment configuration. This allows the attacker to extract sensitive data, including DB connection strings, API keys, and internal service configuration.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: JWKS Cache Sharing Vulnerability in Steeltoe

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's static JWKS cache is shared globally across different schemes and never invalidated, leading to potential identity confusion. The vulnerability is caused by a design flaw in the cache lifecycle management where the cache scope is not sufficiently constrained. A privileged local user can manipulate this to trick the application into trusting attacker-supplied public keys.

Proof of Concept (PoC):

A highly privileged attacker modifies the JWKS endpoint configuration used by the Steeltoe framework. Because the cache is global and never invalidated, the application continues to use the stale, now-malicious keys even after configuration revert or schema changes. The attacker signs subsequent authentication tokens using the key injected into the cache. The application trusts these tokens as legitimate, granting the attacker access to privileged user accounts.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-50267

Finding: Insecure TLS Private Key Storage in Steeltoe

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe fails to protect TLS private keys, storing them in /tmp with default permissions and without implementing a deletion policy. This vulnerability exists because the framework lacks adequate file lifecycle management for sensitive cryptographic material. Consequently, local users with access to the system can read and potentially compromise the TLS keys.

Proof of Concept (PoC):

A local attacker with low privileges probes the /tmp directory of the server hosting the Steeltoe application. The attacker locates the plain-text TLS private key file left by the framework after a service restart. By copying the file, the attacker gains the private key needed to decrypt intercepted TLS traffic. This allows for the subsequent interception and decryption of communication sessions between the server and its clients.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-49292

Finding: Unauthorized DB Access in Kiwi TCMS

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 34/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1068, T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The /init-db/ page in Kiwi TCMS fails to verify if the initialization process has already been completed, allowing the page to remain active after initial setup. This insecure configuration enables re-triggering of sensitive database setup operations by unauthorized users. As a result, an attacker could potentially overwrite or corrupt existing data, impacting system integrity.

Proof of Concept (PoC):

An unauthenticated remote attacker navigates to the /init-db/ endpoint on an active Kiwi TCMS instance. The application fails to check for an existing lockfile or database state, rendering the initialization form as if it were a new installation. The attacker submits the form, triggering the database setup sequence again. This results in the destruction or modification of existing system database records.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50268

Finding: Insecure Padding Configuration in Steeltoe

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local
Privileges Required	High
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Steeltoe framework incorrectly defaults to PKCS#1 v1.5 padding when OAEP settings are specified for cryptographic operations. This configuration error results from a mismatch between the declared security parameters and the internal cryptographic implementation. While difficult to exploit, this significantly lowers the resistance of encrypted data to chosen-ciphertext attacks.

Proof of Concept (PoC):

A highly privileged local user identifies the cryptographic module's configuration within the Steeltoe application. The user monitors the application's process memory during an encryption event, confirming that PKCS#1 v1.5 padding is utilized despite the OAEP declaration. The user then employs a chosen-ciphertext attack against captured encrypted packets to recover plaintext. This results in the gradual exposure of sensitive encrypted data over time.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating

whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>